DOSSIER TECHNIQUE

# Sécurité, évaluation financière et présentation de l'application

*Sections 3.2 à 3.4.4 du rapport de stage*

| | |
|---|---|
| **Projet** | Plateforme ETI de gestion des salles de réunion |
| **Architecture** | Angular 21 · Spring Boot 4.1 · Java 21 · MariaDB/XAMPP |
| **État du relevé** | 19 août 2026 |

**Périmètre.** Ce document est autonome et destiné à être repris dans le rapport. Il repose sur une lecture du code, des migrations et de la base locale, sans modification de la plateforme.

# Note méthodologique

Les constats ci-dessous distinguent trois niveaux : les protections effectivement implémentées, les mécanismes adaptés au développement local, et les renforcements nécessaires avant une mise en production. Cette distinction évite de présenter le prototype comme un système déjà homologué pour un environnement bancaire.

## Périmètre technique observé

- Frontend : Angular 21.2.19, TypeScript 5.9.3, formulaires réactifs et routage par rôle.
- Backend : Java 21, Spring Boot 4.1, Spring Security, Spring Data JPA/Hibernate, Flyway et API REST.
- Données : MariaDB 10.4.32 fournie par XAMPP, schéma eti_rooms, six migrations Flyway et vingt tables techniques (historique Flyway inclus).
- Vérification : 19 scénarios d'intégration backend et 5 tests unitaires frontend sont présents ; les builds de production ont été exécutés avec succès.

**Confidentialité du rapport.** Aucun mot de passe, secret JWT, jeton d'accès ni donnée sensible complète n'est reproduit dans ce document.

# 3.2. Sécurité de l'application

La sécurité est organisée en couches : authentification, autorisation par rôle, contrôle de propriété des données, validation des entrées, intégrité transactionnelle et traçabilité. Le frontend améliore l'expérience utilisateur, mais la décision d'autoriser ou de refuser une action appartient toujours au backend.

## 3.2.1. Authentification et gestion des mots de passe

- Les mots de passe ne sont pas stockés en clair : Spring Security applique BCrypt avec un facteur de coût de 12.
- Les comptes inactifs ou supprimés logiquement ne peuvent plus être authentifiés.
- Les nouveaux mots de passe doivent contenir au minimum 8 caractères, une majuscule, une minuscule, un chiffre et un caractère spécial, sans espace.
- La création, la modification et la suppression d'un utilisateur exigent la ressaisie du mot de passe de l'administrateur ; une suppression exige aussi une confirmation explicite.
- Après connexion, un jeton signé HMAC-SHA256 transporte l'identité, les rôles et une date d'expiration. L'API fonctionne sans session serveur (mode stateless).

**Limite actuelle.** Le jeton est conservé dans localStorage et sa durée par défaut est de 480 minutes. En production, un stockage par cookie HttpOnly/Secure/SameSite, une durée plus courte, une rotation et une révocation côté serveur réduiraient l'impact d'une attaque XSS.

### 3.2.2. Contrôle des accès et confidentialité

Le modèle RBAC (Role-Based Access Control) comprend quatre profils : USER, ADMIN, FACILITY et IT. Les routes Angular masquent les écrans non autorisés, tandis que les méthodes de l'API sont protégées par des règles @PreAuthorize. Le contrôle backend constitue la barrière de sécurité réelle.

| Rôle | Droits principaux |
|---|---|
| USER | Créer une demande, consulter et annuler ses propres demandes, répondre au feedback à J+1. |
| ADMIN | Assigner une salle, définir la priorité, confirmer, administrer salles, équipements et utilisateurs, consulter rapports et audit. |
| FACILITY | Consulter et décider les validations physiques ; visualiser les feedbacks autorisés. |
| IT | Consulter et décider les validations techniques ; gérer les équipements ; visualiser les feedbacks autorisés. |

- Contrôle de propriété : un demandeur ne peut lire, modifier, annuler ou évaluer que sa propre réservation.
- Protection des notifications : un utilisateur ne peut marquer comme lue qu'une notification qui lui appartient.
- Protection administrative : impossibilité de supprimer son propre compte ou le dernier administrateur actif.
- Réponses API minimisées : le hash du mot de passe n'est jamais renvoyé au frontend.

### 3.2.3. Injection SQL et intégrité des données

Les accès aux données passent par Spring Data JPA et Hibernate. Les requêtes déclarées utilisent des paramètres nommés (:email, :id, :role, etc.) au lieu de concaténer les valeurs reçues. Les deux requêtes SQL natives servant au verrouillage utilisent également un paramètre :id. Ce mode d'accès réduit fortement le risque d'injection SQL recommandé par l'OWASP.

- Contraintes relationnelles : clés étrangères, unicité des e-mails, codes, références et couples salle/disposition.
- Contraintes de domaine : capacité et quantité positives, dates cohérentes, notes bornées et une seule réponse par critère.

- Transactions Spring et verrouillage FOR UPDATE pour les opérations concurrentes d'assignation, de modification et de suppression.
- Version optimiste sur les salles et les demandes afin de détecter certaines mises à jour concurrentes.
- Hibernate est configuré en ddl-auto=validate : le schéma attendu est vérifié, mais n'est pas modifié automatiquement.

### 3.2.4. Validation, XSS, CSRF, CORS et téléversement

Les objets reçus par l'API sont validés avec Jakarta Validation : champs obligatoires, formats d'e-mail, longueurs maximales, valeurs numériques et expressions régulières. Des règles métier complètent ces contrôles pour les périodes, horaires, conflits de salles, capacités, équipements, justificatifs et transitions de statut.

| Sujet | Mécanisme actuel | État | Renforcement |
|---|---|---|---|
| XSS | Angular échappe les interpolations affichées et aucun rendu HTML dynamique non maîtrisé n'a été identifié. | Partiel | Ajouter une Content-Security-Policy stricte et conserver l'interdiction de HTML utilisateur. |
| CSRF | Protection Spring désactivée car l'API utilise un jeton Bearer et aucune session cookie. | Adapté au prototype | Réévaluer si le jeton passe dans un cookie ; activer alors une protection CSRF. |
| CORS | Origines autorisées configurables ; localhost:4200 par défaut. Méthodes et en-têtes explicitement limités. | Implémenté | Renseigner uniquement les domaines internes autorisés en production. |
| Photos | Limite 5 Mo, formats PNG/JPEG/WebP, nom UUID, normalisation du chemin et refus des URL externes. | Partiel | Contrôler la signature binaire, réencoder l'image, analyser par antivirus et protéger l'accès public. |
| Erreurs | Réponses structurées ; message technique générique pour les erreurs inattendues. | Implémenté | Centraliser les journaux sans données sensibles et mettre en place des alertes. |

### 3.2.5. Traçabilité, confidentialité et disponibilité

- Journal d'audit : créations, modifications, assignations, validations, annulations et opérations administratives sont associées à l'acteur et à la date.
- Suppression maîtrisée : utilisateurs, salles et équipements peuvent être archivés logiquement pour préserver l'historique et l'intégrité référentielle.
- Notifications persistantes : les événements de workflow restent stockés et sont isolés par utilisateur.
- Flyway versionne les changements de schéma ; les migrations sont validées au démarrage.
- Les conflits de réservation sont recherchés pour chaque occurrence en tenant compte du temps de battement de la salle.

**Données personnelles.** La base contient notamment noms, e-mails, demandes, commentaires, feedbacks et traces d'action. Le prototype ne met pas encore en œuvre une politique formelle de durée de conservation, de purge, de chiffrement au repos ou de gestion des droits d'accès aux sauvegardes.

### 3.2.6. Matrice de sécurité et limites

| Risque | Protection observée | État | Mesure cible |
|---|---|---|---|
| Injection SQL | JPA/Hibernate + paramètres nommés | Implémenté | Conserver les requêtes paramétrées ; compte DB à privilèges minimaux. |
| Mot de passe compromis | BCrypt coût 12 + politique de complexité | Implémenté | Ajouter MFA/SSO d'entreprise, verrouillage et détection d'attaque. |
| Accès non autorisé | JWT + RBAC serveur + contrôles de propriété | Implémenté | Réduire la durée du jeton, révocation et rotation des clés. |
| Conflit de réservation | Transactions, verrous et contrôle par occurrence | Implémenté | Tests de charge et supervision des échecs concurrents. |
| Fuite par upload | Taille/type/UUID/chemin normalisé | Partiel | Signature de fichier, réencodage, antivirus, stockage non exécutable. |
| XSS / vol de jeton | Échappement Angular | Partiel | CSP, en-têtes de sécurité et cookie HttpOnly si architecture adaptée. |
| Interception réseau | Aucune terminaison TLS dans XAMPP local | Développement | HTTPS obligatoire via proxy inverse en production. |
| Attaque par force brute | Message d'erreur non distinctif | À renforcer | Rate limiting, temporisation, verrouillage progressif et journalisation. |
| Perte de données | Historique et soft delete | Partiel | Sauvegardes chiffrées, test de restauration et plan de reprise. |

### 3.2.7. Mesures indispensables avant production

1. Remplacer immédiatement le secret JWT de démonstration par une valeur aléatoire forte conservée dans un coffre de secrets ; interdire toute valeur par défaut.
2. Déployer sous HTTPS via un proxy inverse, activer HSTS et utiliser TLS entre l'application et la base lorsque l'infrastructure le permet.
3. Créer un compte MariaDB dédié sans droits d'administration, avec mot de passe fort ; ne jamais utiliser root en production.
4. Désactiver ou restreindre Swagger/OpenAPI et les endpoints techniques ; limiter l'accès réseau à l'intranet ou au VPN.

5. Mettre en place MFA ou SSO d’entreprise, limitation des tentatives, verrouillage progressif et renouvellement/révocation des jetons.
6. Ajouter CSP, X-Content-Type-Options, Referrer-Policy, Permissions-Policy et une stratégie stricte de cookies/jetons.
7. Analyser les dépendances (SCA), le code (SAST), les secrets et les images téléversées ; corriger les vulnérabilités avant chaque livraison.
8. Définir sauvegardes chiffrées, rétention, restauration testée, supervision, alertes et procédure de réponse à incident.

## 3.3. Évaluation financière de la solution

L'évaluation suivante est indicative. Elle valorise le temps de réalisation et un scénario de mise en production interne ; elle ne constitue ni un devis fournisseur ni un coût réellement engagé par Ecobank. Les technologies utilisées sont majoritairement open source et n'entraînent pas de licence logicielle directe pour le prototype.

### 3.3.1. Hypothèses de coût

| Poste | Hypothèse | Montant FCFA | Observation |
|---|---|---|---|
| Conception, développement, tests, documentation | 25 à 40 j × 35 000 FCFA/j | 875 000 à 1 400 000 | Valorisation du travail, non dépense constatée |
| Durcissement sécurité et préparation production | 5 à 10 j × 35 000 FCFA/j | 175 000 à 350 000 | TLS, secrets, sauvegardes, supervision, SSO/MFA |
| Formation et conduite du changement | 2 à 3 j × 35 000 FCFA/j | 70 000 à 105 000 | Administrateur, Facility, IT et demandeurs |
| Licences Angular/Java/Spring/MariaDB/XAMPP | Open source | 0 | Sous réserve du respect des licences des composants |
| Total initial indicatif | Développement + durcissement + formation | 1 120 000 à 1 855 000 | Hors infrastructure déjà disponible |

### 3.3.2. Coûts récurrents

| Poste | Fourchette | Commentaire |
|---|---|---|
| Hébergement/VM interne | 0 à 50 000 / mois | Dépend de la capacité déjà disponible. |
| Sauvegardes et stockage | 5 000 à 20 000 / mois | Copies chiffrées et rétention. |
| Relais e-mail | 0 à 20 000 / mois | Nul si relais interne existant. |
| Supervision et certificats | 0 à 20 000 / mois | Certificat possible sans licence ; exploitation à prévoir. |
| Maintenance corrective/évolutive | 40 000 à 160 000 / mois | 4 à 8 heures à 10 000-20 000 FCFA/h. |
| Total récurrent indicatif | 45 000 à 250 000 / mois | Fourchette dépendante de l'infrastructure interne. |

### 3.3.3. Bénéfices et retour sur investissement

Le bénéfice principal réside dans la réduction du travail manuel, l'évitement des conflits de salles, la traçabilité et la disponibilité immédiate des rapports. Un scénario pédagogique peut être calculé comme suit :

| Gain | Hypothèse | Valeur FCFA |
|---|---|---|
| Traitement manuel évité | 100 demandes/mois × 15 min × 5 000 FCFA/h | 125 000 / mois |
| Conflits et reprises évités | 2 incidents/mois × 2 h × 3 acteurs × 5 000 FCFA/h | 60 000 / mois |
| Production de rapports | 8 h/mois × 5 000 FCFA/h | 40 000 / mois |
| Bénéfice brut théorique | Somme des trois postes | 225 000 / mois |

**Lecture du résultat.** Avec ces hypothèses, le retour sur l'investissement initial se situe approximativement entre 5 et 9 mois, avant prise en compte des coûts récurrents. Le calcul doit être recalibré avec le volume réel de demandes, le coût horaire interne et le nombre d'incidents effectivement évités.

### 3.3.4. Conclusion financière

La solution présente un coût de licence faible, mais la mise en production sécurisée représente l'essentiel de l'investissement : infrastructure, durcissement, sauvegardes, supervision et maintenance. La valeur attendue est surtout opérationnelle et qualitative : centralisation, transparence du workflow, réduction des erreurs, meilleure utilisation des salles et disponibilité d'indicateurs fiables.

## 3.4. Présentation de l'application

L'application est une plateforme web bilingue destinée à la gestion centralisée des salles ETI. Elle couvre la demande, l'assignation, les validations physiques et techniques, la confirmation, les notifications, le feedback à J+1, l'administration du référentiel et le reporting.

### 3.4.1. Mise en place de la base de données

En développement, la base s'appuie sur MariaDB 10.4.32 via XAMPP. Le backend communique avec elle par JDBC ; Spring Data JPA/Hibernate réalise le mapping objet-relationnel et Flyway applique les évolutions du schéma de manière versionnée.

1. Démarrer le module MySQL de XAMPP sur le port 3306.
2. Configurer DB_URL, DB_USER et DB_PASSWORD dans les variables d'environnement ; le projet local utilise la base eti_rooms.
3. Démarrer le backend Spring Boot. Flyway vérifie les six migrations et crée/met à jour le schéma si nécessaire.
4. Hibernate exécute ensuite une validation de conformité du modèle (ddl-auto=validate).
5. Contrôler l'état avec l'endpoint de santé et phpMyAdmin, sans modifier manuellement les tables gérées par Flyway.

| Élément | Choix retenu |
|---|---|
| SGBD local | MariaDB 10.4.32 / XAMPP |
| Base | eti_rooms |
| Accès applicatif | JDBC + MySQL Connector/J |
| ORM | Spring Data JPA / Hibernate |
| Migrations | Flyway : V1 à V6 |
| Tables | 20, historique Flyway inclus |
| Fuseau horaire | Africa/Lome |
| Stratégie DDL | Validation, pas de génération automatique |

**Important pour la production.** Le compte root sans mot de passe et useSSL=false sont propres au poste XAMPP de développement. Ils doivent être remplacés par un compte dédié à privilèges minimaux, une authentification forte et une connexion chiffrée.

## Modèle logique de données simplifié

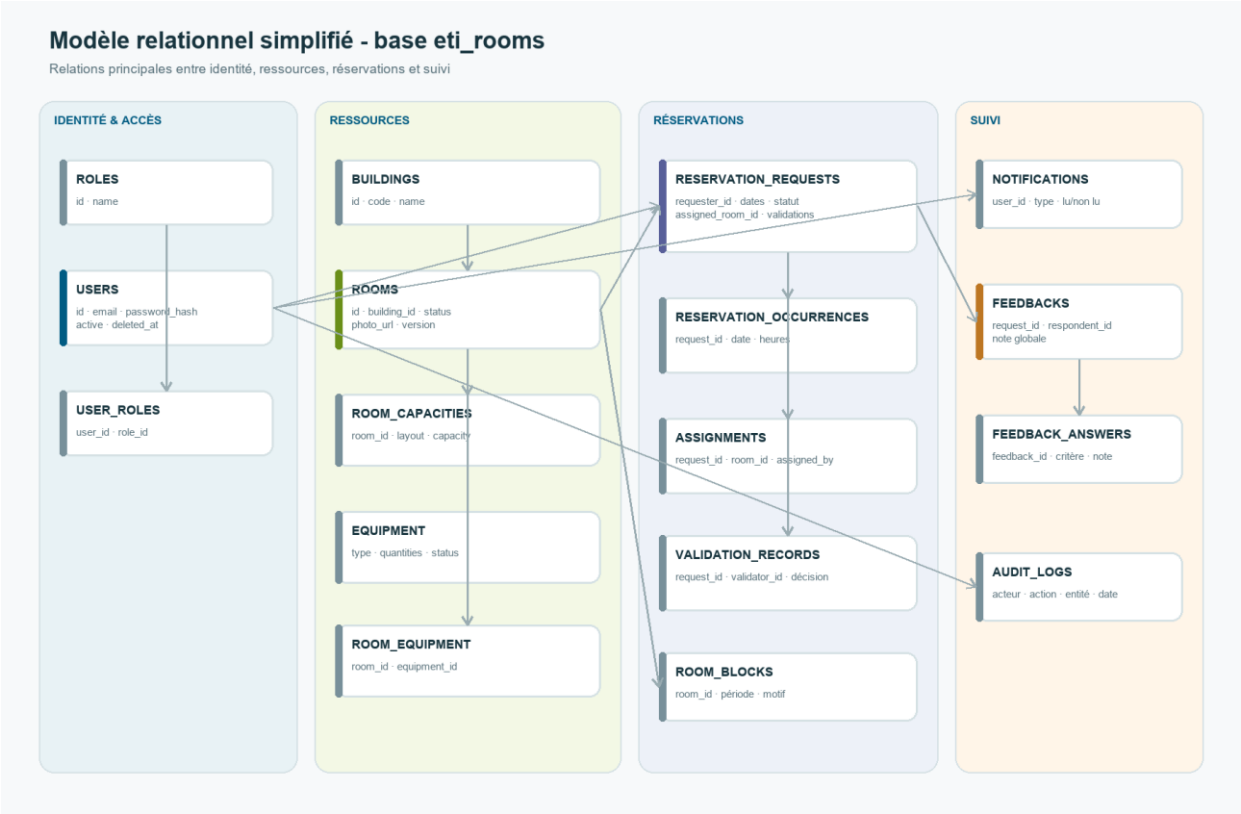



*Figure 1 - Relations principales de la base eti_rooms (schéma simplifié).*

Le modèle sépare les identités, le référentiel des ressources, le cycle de réservation et les données de suivi. Les tables d'occurrences permettent de représenter une réservation sur plusieurs journées avec des horaires différents. Les tables d'assignation et de validation conservent l'historique du workflow, tandis que les feedbacks et réponses détaillent la satisfaction post-événement.

### 3.4.2. Plan de navigation

Après authentification, l'utilisateur est dirigé vers un espace adapté à son rôle. Les fonctions transversales restent accessibles à tous : planning, salles, feedbacks, notifications, langue FR/EN et tutoriels d'utilisation.

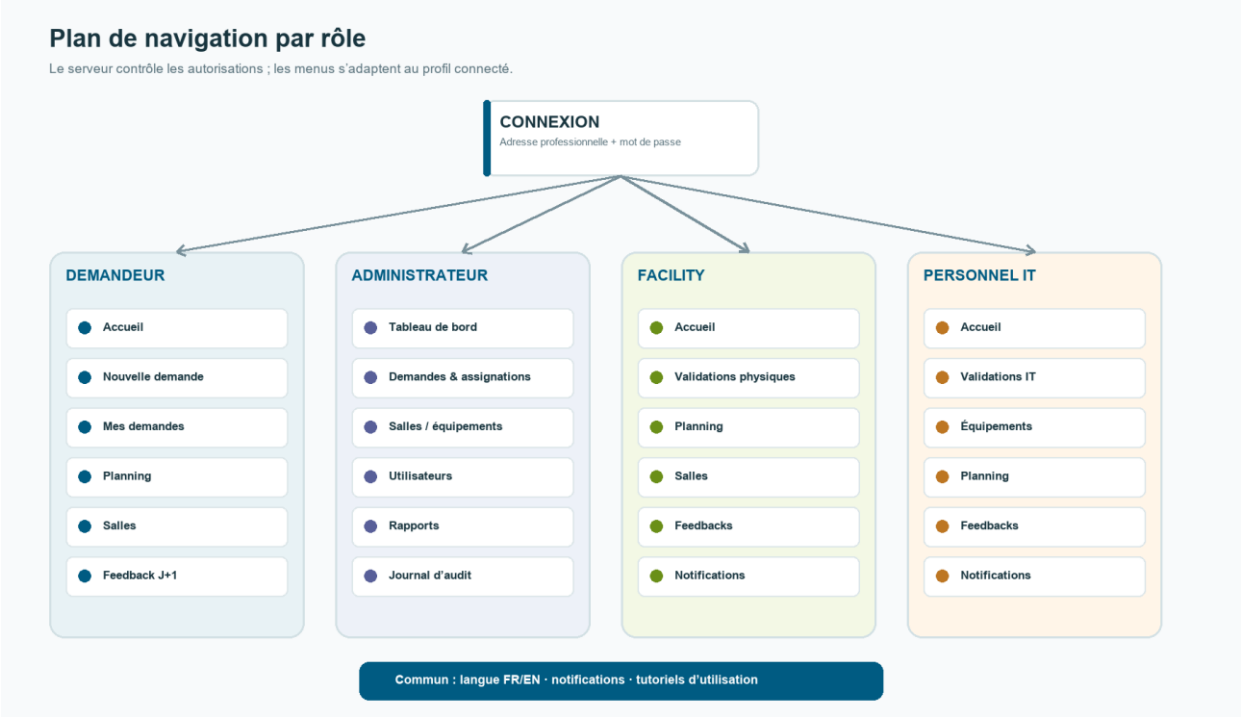



*Figure 2 - Organisation de la navigation selon les quatre profils.*

| Acteur | Parcours principal | Accès complémentaires |
|---|---|---|
| Demandeur | Accueil → nouvelle demande → mes demandes → feedback J+1 | Planning, salles, notifications, tutoriels |
| Administrateur | Tableau de bord → demandes/assignations → confirmation | Salles, équipements, utilisateurs, rapports, audit |
| Facility | Accueil → file Facility → validation/rejet | Planning, salles, feedbacks, notifications |
| IT | Accueil → file IT → validation/rejet | Équipements, planning, feedbacks, notifications |

### 3.4.3. Quelques masques de saisie

Quatre masques significatifs sont retenus afin de présenter le fonctionnement sans surcharger le rapport. Les figures suivantes sont des représentations documentaires fidèles à la structure de l'interface ; elles peuvent être remplacées par des captures finales si nécessaire.

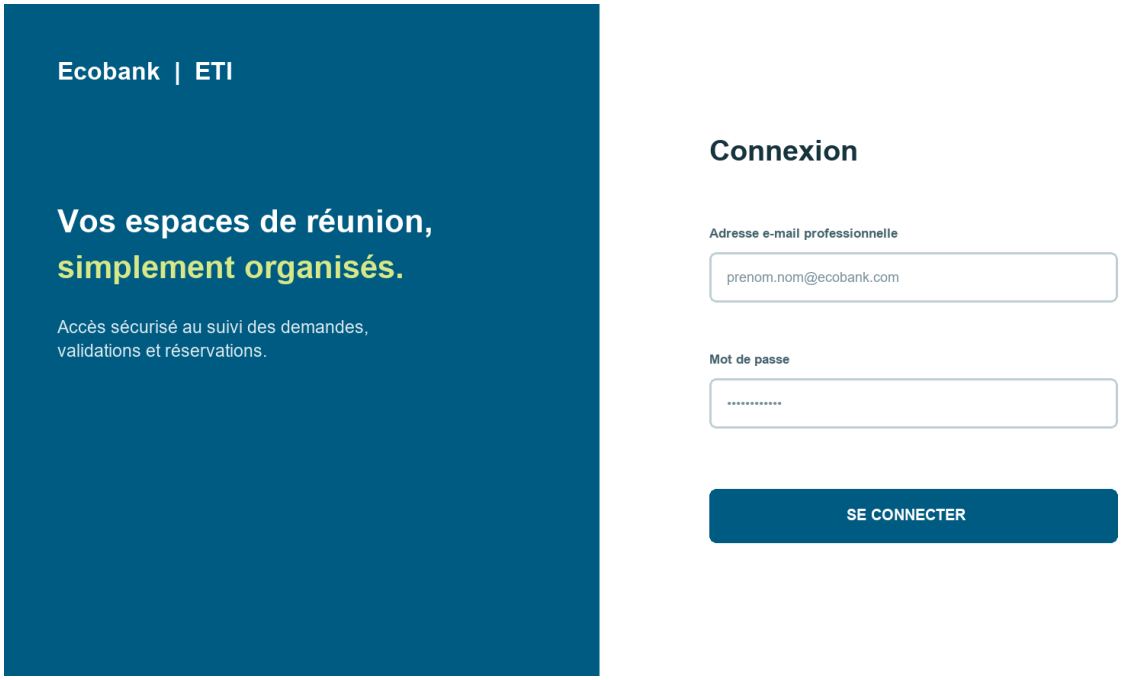



*Figure 3 - Masque de connexion.*

Le formulaire recueille l'adresse e-mail professionnelle et le mot de passe. Le champ mot de passe est masqué, les erreurs d'authentification restent génériques et l'utilisateur est redirigé selon son rôle.

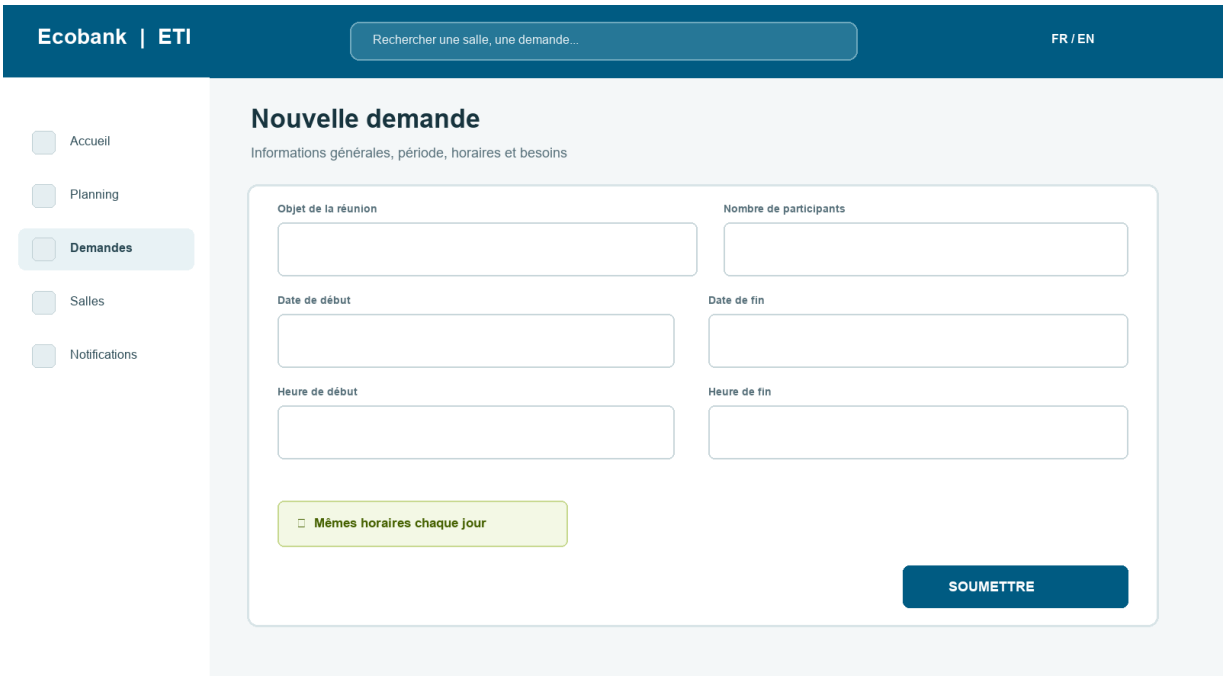



*Figure 4 - Création d'une demande de réservation.*

Le demandeur renseigne l'objet, les participants, les dates, les horaires, la disposition et les besoins. Pour une période multi-jours, il peut conserver les mêmes horaires ou préciser chaque journée.

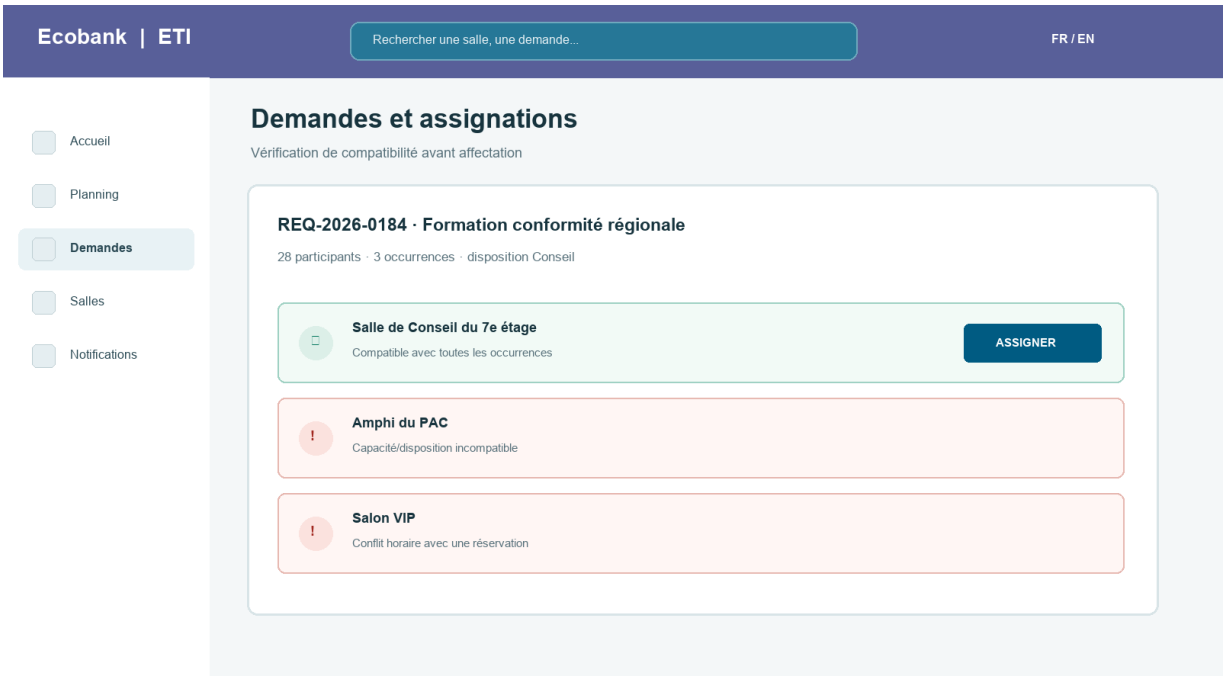



*Figure 5 - Vérification et assignation d'une salle.*

L'administrateur visualise toutes les salles avec les motifs de compatibilité ou d'incompatibilité. L'assignation n'est possible que si la capacité, la disposition, les équipements, les blocages et les conflits horaires sont satisfaits.

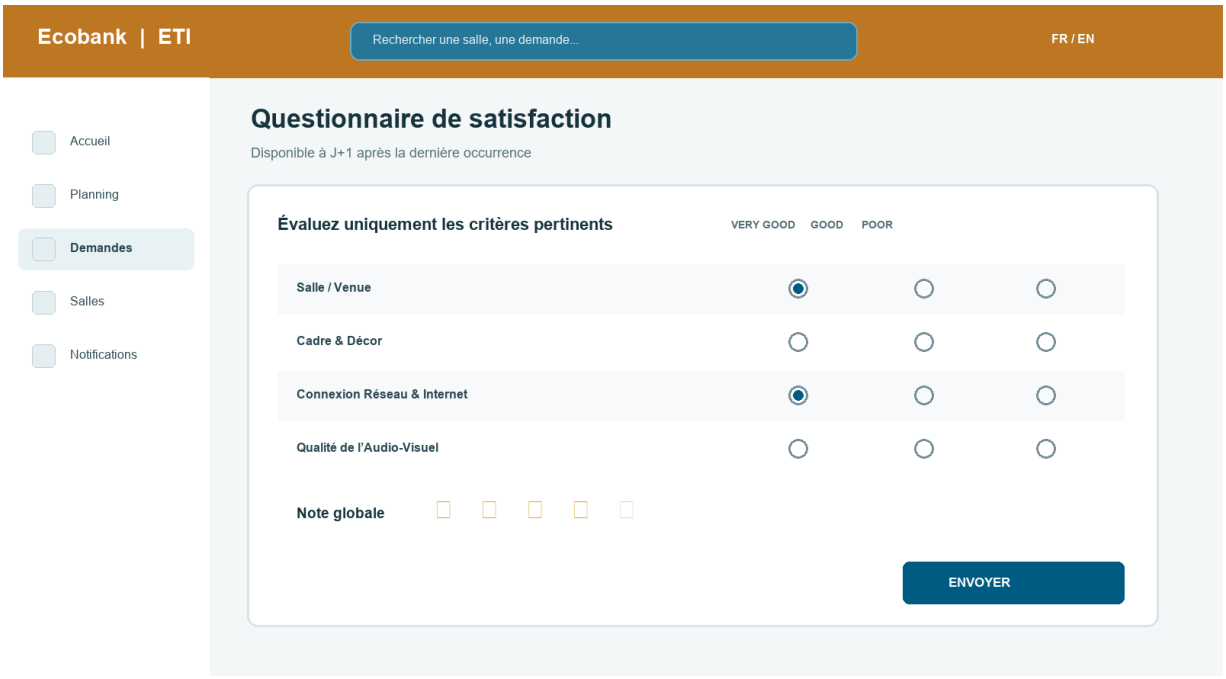



*Figure 6 - Questionnaire de satisfaction à J+1.*

Après la dernière occurrence, le demandeur peut noter seulement les critères pertinents parmi 19 thèmes, ajouter une note globale sur 5 et un commentaire. Une réservation ne reçoit qu'un seul feedback.

### 3.4.4. Quelques états et statistiques

L'application met à disposition un tableau de bord et des exports PDF/Excel. Les indicateurs ci-dessous proviennent d'une lecture de la base locale au 19 août 2026. Ils servent à illustrer le fonctionnement ; avec seulement trois demandes et un feedback, ils ne doivent pas être interprétés comme une mesure définitive de performance.

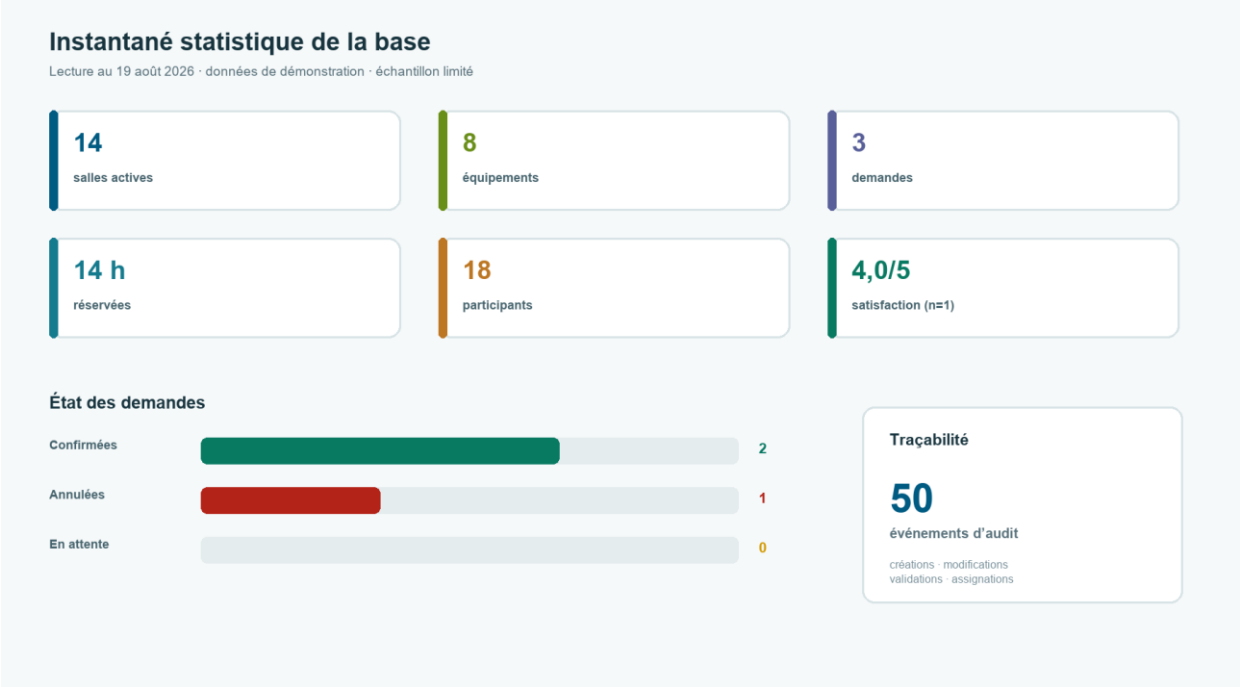



*Figure 7 - Instantané des principaux indicateurs de la base de démonstration.*

| Indicateur | Valeur observée | Utilité |
|---|---|---|
| Ressources disponibles | 14 salles actives ; 8 équipements référencés | Mesure la couverture du catalogue et facilite la maintenance du référentiel. |
| Activité | 3 demandes ; 4 occurrences | Distingue une demande métier des créneaux journaliers qu'elle génère. |
| État du workflow | 2 confirmées ; 1 annulée ; 0 en attente | Permet de suivre les dossiers à traiter et le résultat du cycle de validation. |
| Temps réservé | 14,0 heures hors demandes annulées | Quantifie la charge d'occupation et alimente le taux d'utilisation. |
| Participants | 18 participants cumulés ; moyenne 9 par demande active | Aide à ajuster la capacité des salles et les dispositions. |
| Satisfaction | 4,0/5 sur 1 feedback | Suit la qualité perçue ; l'échantillon est insuffisant pour conclure. |
| Priorité | 1 demande prioritaire | Aide l'administrateur à ordonner le traitement des demandes. |
| Traçabilité | 50 événements dans le journal d'audit | Permet de rechercher qui a réalisé quelle action et à quel moment. |
| Salles les plus assignées | Amphi du PAC et Auditorium de l'Académie : 1 chacune | Identifie les salles les plus sollicitées et prépare les décisions de maintenance. |

### Indicateurs calculés par le tableau de bord

- Nombre total de demandes et ventilation par statut.
- Heures réservées et nombre cumulé de participants, hors annulations.
- Taux d'occupation théorique des 14 salles sur une amplitude de 12 heures par jour.
- Demandes en attente, annulées et prioritaires.
- Note moyenne issue des feedbacks et classement des huit salles les plus assignées.
- Répartition des réservations par bâtiment.

## Conclusion des sections

La plateforme met en œuvre une base de sécurité cohérente pour un prototype fonctionnel : mots de passe BCrypt, authentification par jeton, contrôle d'accès par rôle, requêtes JPA paramétrées, validations, transactions, contraintes SQL et audit. Elle centralise l'ensemble du processus de réservation et produit des indicateurs utiles. Une mise en production en contexte bancaire nécessite cependant un durcissement complémentaire, en particulier HTTPS, coffre de secrets, compte base de données dédié, SSO/MFA, limitation des tentatives, supervision, sauvegardes testées et politique de confidentialité.

## Références techniques


- Code interne du projet : SecurityConfig, TokenService, ApiDtos, ReservationService, RoomPhotoStorage, Repositories et ReportingService.
- Migrations Flyway : V1__initial_schema.sql à V6__feedback_overall_rating.sql.
- Configuration : application.yml, pom.xml, package.json et routes Angular.
- OWASP Cheat Sheet Series, « SQL Injection Prevention Cheat Sheet », cheatsheetseries.owasp.org, consulté le 19 août 2026.
- OWASP Cheat Sheet Series, « Password Storage Cheat Sheet », cheatsheetseries.owasp.org, consulté le 19 août 2026.
- OWASP Cheat Sheet Series, « JSON Web Token for Java Cheat Sheet », cheatsheetseries.owasp.org, consulté le 19 août 2026.
- OWASP Cheat Sheet Series, « Cross Site Scripting Prevention Cheat Sheet », cheatsheetseries.owasp.org, consulté le 19 août 2026.